OPENCYBERPATH

SOC & SIEM Fundamentals

From first security words to evidence-based investigation

NOTEBOOK 01 • BEGINNER → INTERMEDIATE → ADVANCED • REVISION EDITION

> NOTEBOOK PROMISE Plain language first. Define every important word. Show the clue, explain what it does and does not prove, then choose a safe next step.

By the end, you can…

- Explain what a SOC analyst does and how a SIEM helps.
- Tell an event, an alert, and an incident apart.
- Read basic synthetic log records without panicking at unfamiliar fields.
- Triage alerts, test explanations, and record evidence clearly.
- Understand detection quality, threat hunting, and incident response at a beginner-friendly level.

> SAFETY + HONESTY These notes teach defensive analysis. Sample records are fictional. Do not investigate real people or devices without permission, and never treat one alert as proof by itself.

How to study: read one section, cover it, explain it aloud, then try the worked example before checking the answer.

Start here: what are we learning?

Cybersecurity is the work of protecting computers, accounts, networks, applications, and information. Security operations focuses on noticing when something may be wrong and helping the right people respond.

A SOC is a Security Operations Center. It may be a physical team, a virtual team, or a group that performs security monitoring as part of another IT function. People in a SOC watch security signals, ask questions, and coordinate response.

A SIEM means Security Information and Event Management. Think of it as a searchable notebook that collects records from different systems, makes the fields more consistent, and helps rules or analysts spot patterns.

> REMEMBER A SIEM can collect and organise evidence, but it cannot magically know every event is malicious. A human still needs context and careful reasoning.

The simplest picture

Part	Think of it as...	Purpose
Log / event	A receipt or diary entry	Records one thing that happened.
Detection rule	A question or filter	Looks for a pattern that deserves attention.
Alert	A reminder to check something	Points an analyst toward a possible issue.
Incident	A tracked investigation	Groups related evidence, decisions, and actions.
Response	The agreed next action	Contains, fixes, restores, and learns when needed.

LEVEL 01

Beginner foundations

Learn the language, follow the event trail, and ask simple evidence questions.

> YOUR GOAL Finish this level when you can explain the ideas in your own words and complete its practice without copying the answer.

1. The everyday words of security

Word	Easy meaning	Small example
Asset	Something valuable to protect	A student database or laptop.
Threat	Something that could cause harm	A scammer trying to steal an account.
Vulnerability	A weakness that could be used	An old application with a known flaw.
Risk	The chance and impact of harm	A public database may expose private records.
Control	A safeguard that lowers risk	MFA, backups, access limits, logging.
Indicator	A clue that may be relevant	An unfamiliar sign-in location or file hash.
Baseline	What normal usually looks like	Typical logins for a service account.

2. A simple telemetry journey

From an event to a human decision

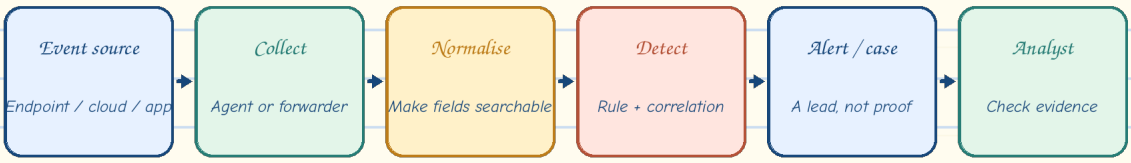


FIGURE 01 • The path from a source event to analyst review

1. A device or service records an event, such as a login or process start.
2. An agent, collector, or cloud connector forwards the record.
3. The SIEM parses the record into fields, such as time, user, host, and result.

4. A rule checks for a condition, or an analyst searches for a pattern.
5. An alert may be created. Several related alerts may be grouped into a case.
6. The analyst validates the context, records a decision, and escalates when required.

> DO NOT SKIP THE MIDDLE If the collection time, timezone, host name, or user identity is wrong, a timeline may be misleading. Check the data before trusting a pattern.

3. Log fields you should recognise

Field	Ask this question
timestamp	When did it happen? Is the timezone UTC or local?
host / device	Which computer or service is involved?
user / account	Which identity was used? Is this account expected here?
event type / ID	What kind of action does this provider say happened?
process / application	Which program or service produced the event?
source / destination	Which endpoints are involved, and is the data trustworthy?
result / status	Was the action successful, failed, denied, or unknown?
rule / severity	Which condition triggered? Severity helps prioritise; it does not prove impact.

4. Read a fictional event record

> SYNTHETIC RECORD time=2026-10-01 08:14 UTC | host=LAB-PC-02 | user=student.demo | event=login | result=failed | source=192.0.2.45

What can we say? The record reports a failed login for a fictional practice account at a given time on a named lab device. What can we not say yet? We cannot prove that the account was compromised, that the source address identifies a person, or that the log source is complete.

5. Beginner triage checklist

A careful alert-triage flow

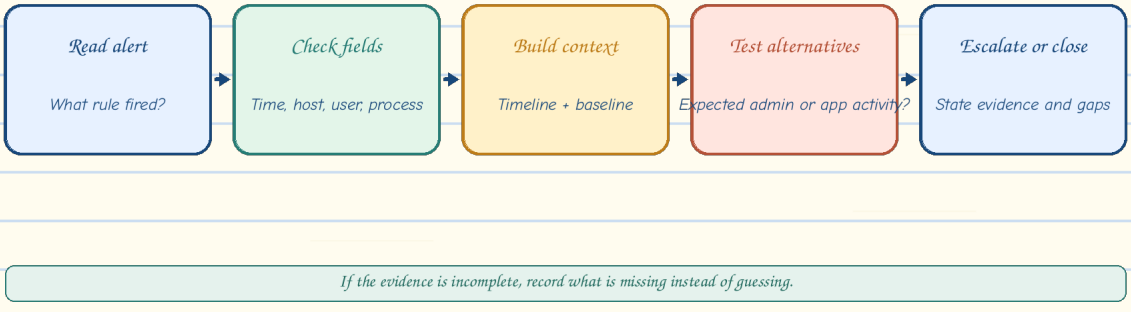


FIGURE 02 • A repeatable alert-triage sequence

- Read the alert title and its rule logic. What exactly did it detect?

- Open the source event. Check its timestamp, timezone, host, identity, and outcome.
- Look at related events before and after the alert, if available.
- Ask whether normal administration, a scheduled job, or a user mistake could explain the event.
- Write the facts separately from assumptions. Include missing data.
- Follow the exercise or organisation's escalation process; do not improvise risky response actions.

6. Beginner practice: what would you say?

A training dashboard shows two failed sign-ins for an account and no successful sign-in in the sample. The account owner says they mistyped their password. The dataset contains only those two rows.

7. Which facts are directly supported by the sample?
8. What is one reasonable benign explanation?
9. What additional record would help you understand the activity?
10. Write one careful sentence for your case notes.

> GOOD ANSWER SHAPE "The sample contains two failed sign-ins for account X at times A and B. The cause is not established. I would review the surrounding authentication events and confirm the timestamps and expected activity."

LEVEL 02

Intermediate investigations

Connect records, build a timeline, test a hypothesis, and explain why a detection fired.

> YOUR GOAL Finish this level when you can explain the ideas in your own words and complete its practice without copying the answer.

7. A practical triage workflow

Step	What you do	Output to save
1. Scope	Confirm the alert, affected asset, time range, and known constraints.	Case ID + question being investigated.
2. Validate	Check raw events, field meaning, collection health, and time settings.	Evidence links / record IDs.
3. Build timeline	Order relevant events and preserve the original timestamps.	Timeline with timezone noted.
4. Compare	Compare activity to baseline, peer accounts, or similar hosts.	Normal vs unusual observations.
5. Test explanations	Write at least one benign and one concerning explanation.	Evidence for and against each.
6. Decide / escalate	Use the severity guide and response procedure.	Disposition, rationale, and next owner.

8. Worked example: repeated sign-in failures

Scenario: a synthetic authentication dataset contains multiple failed sign-ins for a fictional account, followed later by one successful sign-in. This can happen when a user forgets a password. It can also be a clue that someone guessed credentials. The pattern tells you what to investigate; it does not prove which explanation is true.

Time (UTC)	Account	Result	Training note
09:01:03	learner.demo	Failed	Fictional sample.
09:01:18	learner.demo	Failed	Same identity; check source and normal baseline.
09:01:33	learner.demo	Failed	Three failures alone do not prove an attack.
09:04:52	learner.demo	Success	Review device, MFA, session, and expected user activity.

Questions to test the story

- Did the source device or network change between failures and success?
- Was multi-factor authentication completed, challenged, or bypassed according to the logs?
- Is the login time normal for this account?
- Was there a sensitive action after the successful sign-in?
- Are the relevant logs complete, time-aligned, and from trusted sources?

> CAREFUL WORDING "The sequence is unusual relative to the sample baseline and needs validation." is stronger analysis than "This is definitely a hacker."

9. Indicators, behaviours, and context

Clue type	Meaning	Caution
Indicator of compromise (IOC)	A clue such as a file hash, domain, or IP address linked to a case.	Indicators can be old, shared, mislabelled, or absent.
Behaviour / technique	A description of what an actor did, such as phishing or credential access.	The same behaviour may have legitimate explanations.
Context	Time, user role, asset criticality, baseline, change ticket, and related events.	Context can be incomplete; state the gaps.

10. Detection rules in plain English

A detection rule is a testable statement about events. A good rule states which data source it needs, which fields it checks, what time window it uses, what known benign cases may trigger it, and what an analyst should do next.

> TOY RULE (NOT A PRODUCTION RULE) IF a fictional account has 8 or more failed sign-ins in 10 minutes, THEN create an alert for review. Exclude known test accounts only when the owner and exclusion are documented.

Why call it a toy rule? The threshold is made up for practice. Real environments need a baseline, expected traffic, source reliability, documented exclusions, and testing before a rule is enabled.

11. MITRE ATT&CK: a shared map

MITRE ATT&CK groups observed adversary behaviours into tactics and techniques. A tactic is the goal or stage an actor is trying to achieve; a technique is a behaviour used to pursue that goal. Defenders use ATT&CK to describe behaviours, identify visibility gaps, and plan detections.

Example tactic	Plain-language idea	Possible defensive question
Initial access	How did activity first reach an environment?	Do email, web, identity, or remote-access records show the entry point?
Credential access	Was an attempt made to obtain account secrets?	Are there unusual sign-ins or credential-related alerts?
Discovery	What information about systems or accounts was explored?	Is the activity expected for this user or tool?
Lateral movement	Did activity move between systems?	Do authentication and endpoint logs show a new host relationship?
Exfiltration	Might data have left the environment?	Are outbound transfers unusual for the asset and data type?
Impact	Was availability, integrity, or recovery affected?	Are services, files, or backups behaving unexpectedly?

> MAPPING IS NOT PROOF An ATT&CK mapping describes a possible behaviour seen in evidence. It does not prove a known group, intent, or full attack chain.

LEVEL 03

Advanced analyst thinking

Tune detections, hunt from a hypothesis, preserve evidence, and write useful reports.

> YOUR GOAL Finish this level when you can explain the ideas in your own words and complete its practice without copying the answer.

12. Measure detection quality honestly

Detection outcomes: four cases

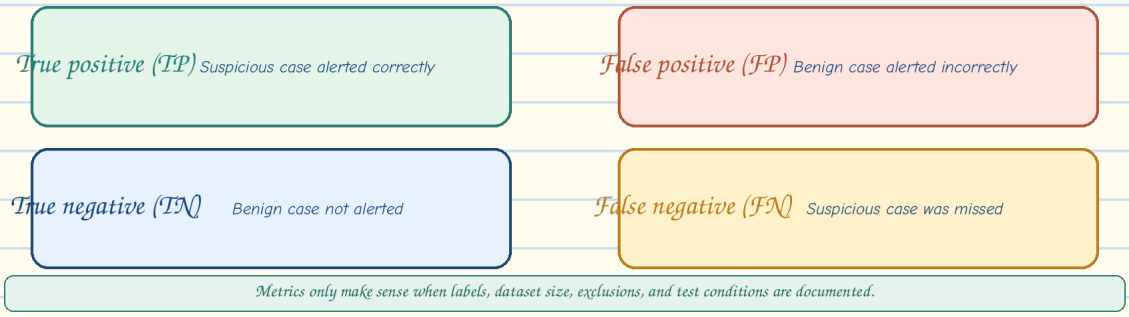


FIGURE 03 • The four outcomes used to evaluate detection rules

Term	Plain meaning	Formula / example
True positive (TP)	A suspicious case was correctly alerted.	The labelled suspicious record was detected.
False positive (FP)	A normal case was incorrectly alerted.	The rule flags a known admin task.
True negative (TN)	A normal case correctly did not alert.	A benign record was not flagged.
False negative (FN)	A suspicious case was missed.	A labelled suspicious record got no alert.
Precision	Of all alerts, how many were true positives?	TP / (TP + FP)
Recall	Of all suspicious cases, how many were found?	TP / (TP + FN)
Specificity	Of benign cases, how many were not flagged?	TN / (TN + FP)
F1 score	A balance measure for precision and recall.	2 × precision × recall / (precision + recall)

> METRIC CAUTION Always report dataset size, labels, exclusions, class balance, and limitations. A neat score on a small

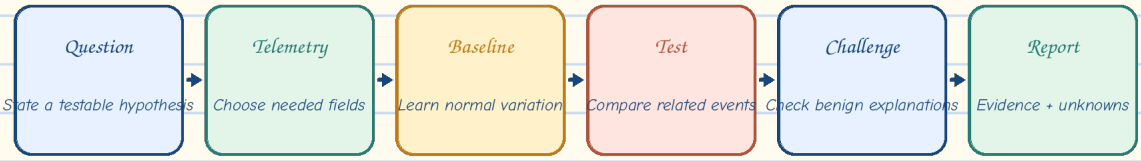
synthetic dataset does not prove production performance.

13. Detection tuning: a controlled comparison

11. Write the detection goal before changing the rule.
12. Record the original logic and the baseline results.
13. Use representative labelled data where possible, including benign cases.
14. Change one meaningful element at a time so you can explain the result.
15. Compare false alerts and missed cases, not just the total number of alerts.
16. Document the trade-off, data limits, owner, review date, and rollback plan.

14. Threat hunting: start with a hypothesis

A threat-hunting investigation loop



A hunt can end with no finding and still be useful when the method and limitations are clear.

FIGURE 04 • A testable hypothesis-to-report loop

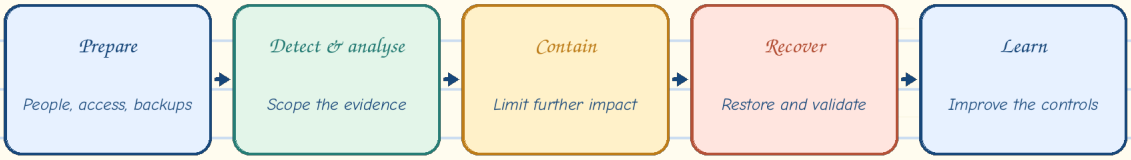
Threat hunting is a planned search through available telemetry to check whether a concerning behaviour may be present. It is not random searching and it is not proof that an attacker exists.

EXAMPLE HYPOTHESIS "If a practice account is being misused, I may see an unusual sign-in time followed by access to a sensitive resource from a new device."

Hunt part	What to write
Hypothesis	One clear statement that could be supported or weakened by evidence.
Data needed	Which logs, fields, time range, and known limitations matter?
Expected baseline	What normal behaviour would look like for this account or service.
Test	The safe query or review steps within your own data and authorised lab.
Result	What was found, what was not found, and what was unavailable.
Next decision	Close, collect more context, tune a rule, or escalate under procedure.

15. Evidence handling and incident notes

Incident response is a managed cycle



Containment decisions belong to the authorised incident process; evidence and impact guide the choice.

FIGURE 05 • A high-level incident-response cycle

- *Preserve the original record or provider reference where policy permits.*
- *Record who collected it, when, from where, and which timezone was used.*
- *Avoid changing the source evidence. Work on copies when needed.*
- *Note any parsing, filtering, normalisation, or exclusion that changed the view.*
- *Keep direct observations separate from interpretation and confidence.*
- *Follow the organisation's evidence-handling, privacy, and escalation rules.*

16. Write a useful case summary

Section	Prompt
Question	What are we trying to determine?
Scope	Which accounts, devices, services, and time window are in scope?
Facts	What directly observed records support the summary?
Reasoning	What explanations fit, and what contradicts them?
Unknowns	Which logs are missing or untrusted?
Action	What is the approved next step, owner, and reason?

> MODEL WRITING "We observed four failed sign-ins from a new source within six minutes, followed by a successful sign-in. The pattern differs from the supplied baseline. Account ownership and the MFA result are not yet confirmed. Recommend verifying with the account owner and reviewing the related session under the incident process."

Final review quiz

17. *What is the difference between an event, an alert, and an incident?*
18. *Name four fields you would validate before trusting a log timeline.*
19. *Why is a successful login after repeated failures worth reviewing but not proof by itself?*
20. *What does precision measure? What does recall measure?*
21. *What is the difference between a hunting hypothesis and a conclusion?*
22. *Name two reasons a detection rule may create false positives.*

23. What information belongs in a case summary besides the final decision?

Answer check

- An event is a recorded action; an alert is a pattern flagged for review; an incident is a tracked case with related evidence and actions.
- Examples: timestamp/timezone, host, user, event ID/type, result, source/destination, process, collection source.
- Both a forgotten password and credential misuse can produce this pattern. Context, MFA, baseline, and follow-on activity help distinguish them.
- Precision = TP/(TP+FP). Recall = TP/(TP+FN).
- A hypothesis is a testable question; a conclusion is a finding supported by the available evidence.
- Examples: expected admin jobs, an unrealistic threshold, missing context, overly broad fields, or an incomplete baseline.
- Scope, evidence references, timestamps, reasoning, alternatives, unknowns, limitations, approved actions, and next owner.

Quick-glossary

Use this as a lookup page. You do not need to memorise every term on the first day.

Word	Plain-language meaning
Agent / collector	A component that gathers and forwards records.
Alert fatigue	When too many low-value alerts make important ones harder to notice.
Correlation	Connecting related records by time, identity, host, or other fields.
Detection logic	The conditions a rule uses to flag a pattern.
False positive	A benign case that was incorrectly flagged.
False negative	A suspicious case that was missed.
IOC	Indicator of compromise; a clue that may relate to harmful activity.
SIEM	Platform for collecting, searching, and correlating security event data.
Telemetry	Records and measurements produced by systems and services.
Triage	The first structured review that decides what needs attention next.

Trusted references & further study

FIELD NOTE • A good analyst can say "I do not know yet." Record the source, timestamp and timezone, the exact observation, an alternative explanation, and the next evidence needed. Keep original evidence unchanged and follow the authorised case process.

These notes simplify the ideas for learning. For exact definitions, implementation details, and updated guidance, return to the original publisher.

SP 800-61 Rev. 3: Incident Response Recommendations — NIST. *Current high-level guidance for preparing for, detecting, responding to, and recovering from incidents.*
https://csrc.nist.gov/pubs/sp/800/61/r3/final

SP 800-86: Guide to Integrating Forensic Techniques into Incident Response — NIST. *Evidence-aware incident investigation and forensic concepts.*
https://csrc.nist.gov/pubs/sp/800/86/final

MITRE ATT&CK Enterprise Matrix — MITRE. *A knowledge base of observed adversary behaviours and defensive mappings.*
https://attack.mitre.org/matrices/enterprise/

Wazuh Getting Started — Wazuh. *A starting point for endpoint events, agents, rules, and alerts.*
https://documentation.wazuh.com/current/getting-started/index.html

Splunk Free Courses — Splunk. *Guided learning for searches, fields, and dashboards.*
https://www.splunk.com/en_us/training/free-courses/overview.html

Windows process creation auditing — Microsoft Learn. *Learn what process-creation audit events can record and the configuration caveats.*
https://learn.microsoft.com/en-us/windows/security/threat-protection/auditing/basic-audit-process-creation

> KEEP LEARNING A good analyst does not copy a tool output and call it truth. They record what they observed, why it matters, what else could explain it, and what should happen next.

A real lab for these notes

Topic: SOC triage, SIEM search, and event correlation. These pages connect the existing OpenCyberPath notes to specific provider-hosted exercises. The card label is intentionally generic; the exact task name and direct URL are listed here so you can open the right exercise instead of a whole catalogue.

Concept checkpoints

- Tell event, alert, incident, and case apart.
- Identify log source, timestamp, host, user, event, result, and outcome.
- Search first, filter second, then compare a pattern with a baseline.
- Document what was observed and what remains unknown.

Log Analysis with SIEM *[TryHackMe]*
https://tryhackme.com/room/loganalysiswithsiem
Access note: Sign-in required; room access and the lab machine entitlement can vary. The page includes a deployable training machine.

Splunk: Exploring SPL *[TryHackMe]*
https://tryhackme.com/room/splunkexploringspl
Access note: Sign-in required; verify current room access before starting. Use the room-provided dataset and Splunk instance.

ACCESS CHECK Open the exact task page and verify the current login, account tier, VM launch button, free/paid terms, and any cost notes before starting. A provider may change availability or retire a challenge.

Before you click Start

- Write down the provider's target/scope and use only the instance it creates for you.
- Keep this notebook beside the exercise. Use its original course data before trying commands on a local machine.
- Capture timestamps, filenames, row/packet IDs, and a short explanation; redact credentials, tokens, and personal data.
- If a page says retired, premium, or downloadable-only, use the alternative listed in the access note or return to the matching interactive lab above.

COMMAND NOTEBOOK - COPY ONE LINE AT A TIME

Commands you can explain

Run searches only inside the lab-provided SIEM or against the bundled synthetic CSV. Do not paste these queries into a production SIEM without your organisation's approval.

First download the matching sample file(s) from the existing card when a command names one. Keep the data in a practice folder and never execute strings stored in evidence.

SPLUNK SPL

```
index=* | stats count by sourcetype
```

Inventory what kinds of records are present. Replace index/field names only after inspecting the training data.

SPLUNK SPL

```
index=* | stats count by host
```

Compare event volume across the training hosts.

SPLUNK SPL

```
index=* (EventCode=4624 OR EventCode=4625) | stats count by EventCode, host
```

Example Windows logon search; the actual field could be EventID or event_id depending on the lab data.

SPLUNK SPL

```
index=* | timechart span=1h count
```

View event volume over time before declaring a burst unusual.

POWERSHELL / CSV

```
Import-Csv .\threat-hunt-auth-dns-samples.csv | Group-Object result | Select-Object Name,Count
```

Count synthetic sign-in outcomes from the supplied file; this does not connect to a live account.

LINUX / CSV

```
head -n 8 threat-hunt-auth-dns-samples.csv
```

Read the sample CSV header and first few fictional rows without modifying it.

COMMAND HABIT Check the current working directory, shell, target, and expected effect before pressing Enter. Save the exact command and the output that mattered.

RUN THE EXERCISE - RECORD WHAT THE EVIDENCE REALLY SHOWS

Guided lab run

- 1. Open the exact SIEM room from the links; start its own lab machine if the page offers one.
- 2. Identify the data source and time range before writing a search.
- 3. Run a broad inventory search, note the available field names, then narrow to one hypothesis.
- 4. Compare failed and successful logons, host, account, and time window. A failed login alone is not proof of compromise.
- 5. Save a short finding with query, result, relevant row IDs, confidence, and next check.

Evidence checklist

- [ ] What exact lab instance or sample file was used?
- [ ] Which command/query and time range produced the observation?
- [ ] What is the directly observed fact, separate from your inference?
- [ ] What benign/alternative explanation could fit?
- [ ] What extra record or control would help confirm the conclusion?

Check your understanding

Q Why is one failed login not enough to claim an attack?

Think it through: A typo or expected user behaviour can cause it; compare frequency, source, account, time, and baseline.

Q What should be written down so another learner can reproduce the result?

Think it through: Exact query, time range, data source, key fields, row count, evidence IDs, and limitations.

Q What is the difference between an alert and an incident?

Think it through: An alert flags activity for review; an incident is a confirmed or managed security event after triage.

NOTEBOOK CLOSE-OUT Finish with: Observation / Evidence source / Why it matters / Alternative explanation / Next check / Limitation. A careful "not enough evidence yet" is a valid professional result.